

SEC105 – Architectures et bonnes pratiques pour la sécurité des systèmes, réseaux données et applications

PEI Millau – Concepteur Architecte Informatique (toutes spécialités)

1

Disponibilité et sureté de fonctionnement

Plan

- Définitions
- Les Datacenter
- ANSI/TIA-942
- Disponibilité et Haute disponibilité
- Les composantes de la haute disponibilité
- RTO / RPO
- PCA / PRA

Définition simple : disponibilité

[WIKIPEDIA]

- Par définition, la disponibilité est l'aptitude d'un bien/d'une entité à être en état d'accomplir une fonction requise dans des conditions données, à un instant donné ou pendant un intervalle de temps donné, en supposant que la fourniture des moyens extérieurs nécessaires soit assurée
- La disponibilité d'un équipement ou d'un système est une mesure de performance qu'on obtient en divisant la durée durant laquelle ledit équipement ou système est opérationnel par la durée totale durant laquelle on aurait souhaité qu'il le soit. On exprime classiquement ce ratio sous forme de pourcentage.

Taux	Temps d'arrêt par an	Temps d'arrêt par mois
90 %	876 heures soit 36,5 jours	72 h
95 %	438 heures soit plus de 18 jours	36 h
99 %	87 heures, 36 minutes soit plus de 3 jours et demi	7,2 h
99,9 %	8 heures, 45 minutes, 36 secondes	43,2 min
99,99 %	52 minutes, 33,6 secondes	4,32 min
99,999 %	5 minutes, 15,36 secondes	25,9 s
99,9999 %	31,68 secondes	2,5 s

Définition simple : Sureté de fonctionnement

[WIKIPEDIA]

- La sûreté de fonctionnement est l'aptitude d'un système à remplir une ou plusieurs fonctions requises dans des conditions données ; elle englobe principalement quatre composantes : la fiabilité, la maintenabilité, la disponibilité et la sécurité.

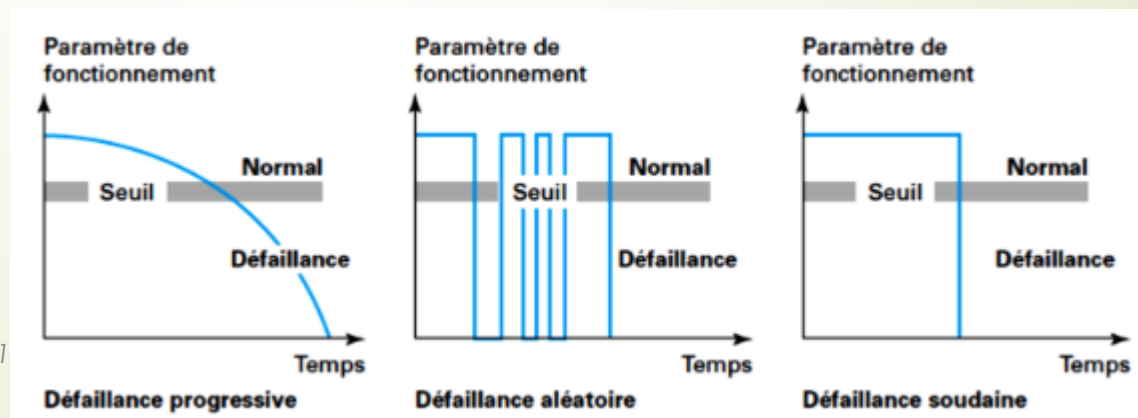
Et par extension:

- la sûreté de fonctionnement désigne également l'étude de cette aptitude et peut ainsi être considérée comme la « science des défaillances et des pannes ».

Sûreté de Fonctionnement			
Aptitude à assurer un service spécifié			
Sécurité	Disponibilité		
Aptitude à ne présenter aucun danger pour les personnes, les biens et l'environnement	Aptitude à être en état de marche à un instant donné ou pendant un intervalle de temps donné		
	Fiabilité	Maintenabilité	Logistique de maintenance
	Aptitude à ne pas présenter des défaillances dans une durée déterminée	Aptitude à être remis en service dans une durée donnée	Politique et moyens de maintenance

Définition simple : Défaillance

- LA DEFAILLANCE, c'est « l'altération ou la cessation de l'aptitude d'un ensemble à accomplir sa ou ses fonction(s) requise(s) avec les performances définies dans les spécifications techniques »
- La cessation de l'aptitude conduit l'entité à être en état de PANNE.
- Dans le cas d'une dégradation sans perte totale de la fonctionnement, on considère qu'il s'agit d'une DEFAILLANCE si sa performance tombe en dessous d'un seuil défini.
- Certains secteurs industriels ont dressés une liste standardisée des défaillances fonctionnelles :



La défaillance

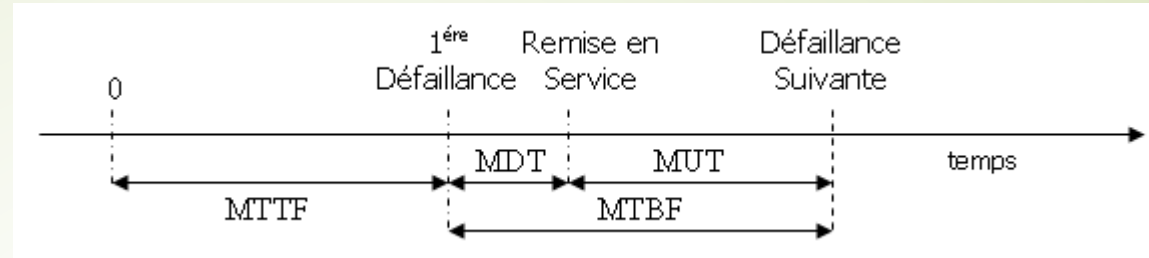
- En général, nous utilisons une échelle de gravité des effets d'une défaillance pour les caractériser. Cette échelle contient traditionnellement 4 catégories :

Défaillance mineure (minor)	Défaillance qui nuit au bon fonctionnement d'un système en causant un dommage négligeable au système ou à son environnement, sans représenter de risque pour l'homme.
Défaillance significative (major)	Défaillance qui nuit au bon fonctionnement du système sans causer de dommage notable au système ou à son environnement sans représenter de risque pour l'homme.
Défaillance critique (hazardous)	Défaillance qui entraîne la perte d'une fonction essentielle du système et cause des dommages importants au système ou à son environnement et ne représentant qu'un risque négligeable pour l'homme.
Défaillance catastrophique (catastrophic)	Défaillance qui entraîne la perte d'une fonction essentielle du système et cause des dommages importants au système ou à son environnement et entraînant des dommages pour l'homme.

Définition simple : Fiabilité

- LA FIABILITE est l'aptitude d'une entité à accomplir une fonction requise pendant un intervalle de temps donné, dans des conditions données.
- La notion de fiabilité induit un vocabulaire spécifique :
 - **MTTF** signifie " Mean Time To Failure " (Temps moyen de fonctionnement avant panne).
 - **MTBF** signifie " Mean Time Between Failure " (Temps moyen entre pannes).
 - **MDT** signifie " Mean Down Time " (Durée moyenne d'indisponibilité)
 - **MUT** signifie " Mean Up Time " (Durée moyenne de fonctionnement après réparation)
 - **MTTR** signifie " Mean Time To Repair " (Durée moyenne de réparation)

La Fiabilité



- Les deux indicateurs utilisés en introduction à la notion et au calcul de fiabilité sont le MTBF et le Taux de panne λ
- « Mean Time Between Failure » - Temps moyen entre les pannes
 - Le MTBF, représente la moyenne des temps de bon fonctionnement entre deux défaillances. Il est souvent calculé sur une période de temps incluant plusieurs défaillances. Ainsi

$$MTBF = \frac{\sum n \text{ temp de bon fonctionnement défaillances (MUT)}}{n}$$

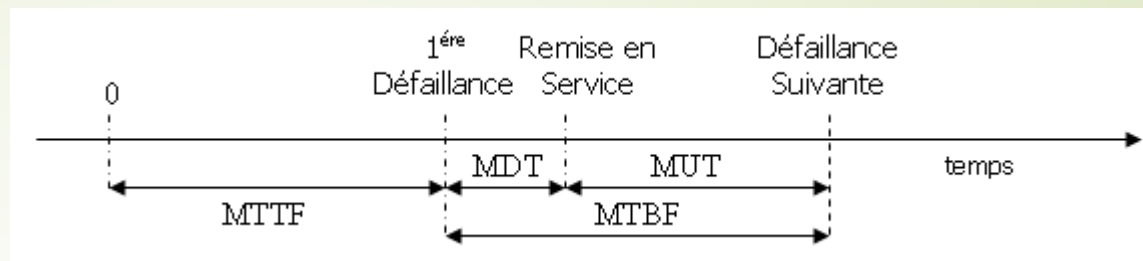
n étant le nombre de défaillances

Taux de panne

Si le taux de pannes est dit constant (cas des composants électroniques), alors d'après la [loi de la fiabilité](#) :

$$\lambda = \frac{1}{MTBF}$$

La Fiabilité



- « Mean Time To Failure »

$$MTTF = \frac{\sum n \text{ Durée moyenne de fonctionnement}}{n}$$

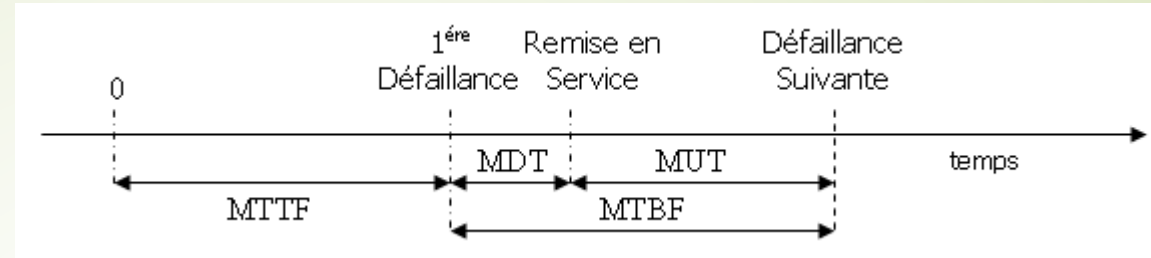
Avec dans l'exemple, durée moyenne de fonctionnement = MTTF + somme(MUT)

- « Mean Time To Repair », ou indice de maintenabilité

$$MTTR = \frac{\text{Temps d'arrêt total}}{\text{nombre d'arrêt}}$$

Cet indicateur définit clairement le temps moyen pour réparer, et exprime la moyenne du temps des tâches de réparation. Il est calculé en additionnant les temps actifs de maintenance ainsi que les temps annexes de maintenance, le tout divisé par le nombre d'interventions.

Par Temps actifs on entend l'ensemble des temps :	Les temps annexes comprennent les temps :
• de localisation de la défaillance • de diagnostic • d'intervention • de contrôles et d'essais	• de détection • d'appels à la maintenance • d'arrivée de la maintenance • propre à la logistique d'intervention



► Le taux de disponibilité

- Cette notion exprime la probabilité qu'une entité soit en un état de « disponibilité » dans des conditions données à un instant donné en supposant que la fourniture de moyens extérieurs soit assurée.
- Elle correspond au rapport entre le temps effectif de disponibilité / le temps requis

- Elle s'exprime de la manière suivante :

$$\text{Disponibilité} = \frac{MTBF}{MTTR + MTBF}$$

- Pour faire plus simple :

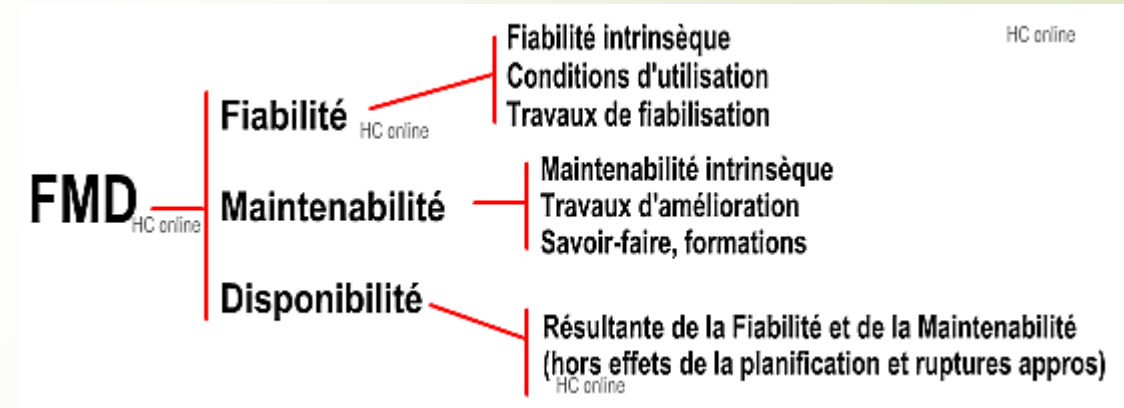
La disponibilité, c'est $\frac{\text{temps moyen entre les pannes}}{\text{Durée moyenne de réparations} + \text{temps moyen entre les pannes}}$

- L'abréviation « FMD » désigne le trio **F**iabilité, **M**aintenabilité, **D**isponibilité, avec :

- $Fiabilité = \frac{1}{MTBF}$

- $Maintenabilité = \frac{1}{MTTR}$

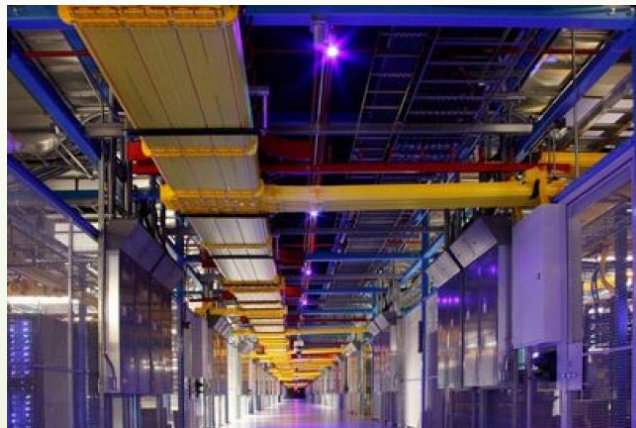
- $Disponibilité = \frac{MTBF}{(MTTR + MTBF)}$



Ces indicateurs permettent de classer les machines selon leurs valeurs et de décider d'une politique ou des priorités d'action circonstanciées.

Définition simple : Datacenter

- Un centre de données (en anglais data center ou data centre) est un lieu (et un service) regroupant des équipements constituant le système d'information d'une ou plusieurs entreprise(s) (ordinateurs centraux, serveurs, baies de stockage, équipements réseaux et de télécommunications, etc.).
- Il peut être interne et/ou externe à l'entreprise, exploité ou non avec le soutien de prestataires.
- Il remplit une mission critique relative à l'informatique et à la télématique en environnement contrôlé (climatisation) et sécurité (système anti-incendie, contre le vol et l'intrusion, etc.), avec une alimentation d'urgence et redondante.



Composantes d'un datacenter

- Elles doivent pour chaque centre assurer la bonne connexion réseau (internet, intranet, etc.) et une haute disponibilité du système d'information.
- Pour cela, des applications logicielles gèrent les tâches essentielles de l'« activité métier » des clients.

Composantes physiques habituellement présentes :

- Climatisation (précise et stable)
- Contrôle de la poussière (filtration de l'air)
- Unité de distribution de l'énergie
- Bloc d'alimentation d'urgence, et une unité de secours (Générateur, UPS)
- Système perfectionné d'alerte d'incendie
- Extinction automatique des incendies (par micro-gouttelettes ou gaz inerte)
- Plancher surélevé
- Conduites pour câbles au-dessus et au-dessous du plancher
- Surveillance par caméras en circuit fermé
- Contrôle des accès, ainsi que sécurité physique
- Surveillance 24/7 des serveurs dédiés (ordinateurs)
- Service de sécurité continuellement présent
- Câbles de paires torsadées de cuivre en Ethernet (Fast ou Gigabit) pour liaisons inter-[jarretières/switches/routeurs/firewall]
- Fibres optiques pour liaisons inter-sites ou inter-[jarretières/switches/routeurs/firewall]

Norme ANSI/TIA-942 et niveaux de disponibilité d'un DataCenter

- Conçu comme un guide pour les ingénieurs et les installateurs de Data Centres, le standard TIA942 (2005) nous offre toute une série de recommandations et directives (guidelines) pour l'installation de leurs infrastructures. La dernière version date de mai 2022.
- Approuvé en 2005 par ANSI-TIA (American National Standards Institute- Telecommunications Industry Association), il classe ce type de centres en plusieurs groupes, appelés **TIER**, qui nous indiquent le niveau de fiabilité, en fonction de la disponibilité.

Le dessin des Data Centres en conformité avec le standard, offre des avantages fondamentaux, tels que:

- Nomenclature standard.
- Fonctionnement à toute épreuve (zéro défauts).
- Augmentation de la protection face aux agents externes.
- Fiabilité à long délai, avec une augmentation des capacités de croissance.

Norme ANSI/TIA-942 et niveaux de disponibilité d'un DataCenter

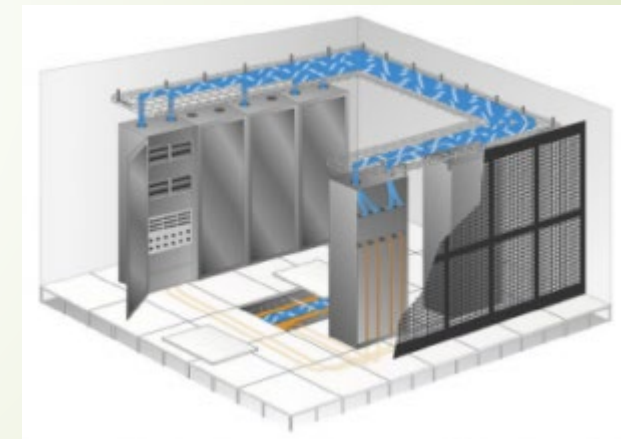
D'après TIA942, l'infrastructure qui supporte un Data Center est formée par quatre sous-systèmes:

- **Télécommunications:** Câblage des armoires et horizontal, accès redondants, cabinet d'entrée, aire de distribution, backbone, éléments actifs et alimentation redondants, patch panels et jarretières, documentation.
- **Architecture :** Choix de l'emplacement, type de bâtiment, protection contre le feu et requêtes d'après NFPA75 (systèmes de protection de l'information contre la flamme), barrières de vapeur, plafonds et sols , Télé surveillance, NOC (Network Operations Center)
- **Système électrique:** Quantité d'accès, points de défaut, charges critiques, redondance et topologie des UPs, mise à la terre, EPO (EmergencyPower Off), batteries, monitoring des générateurs, systèmes de transfert.
- **Système mécanique :** Climatisation, pression positive, tubes et drainages, CRACs et condensateurs, contrôle du HVAC(High Ventilating Air Conditionning), détection du feu et sprinklers, extinction par agent propre (NFPA 2001), détection par aspiration (ASD) détection de liquides.

Norme ANSI/TIA-942 et niveaux de disponibilité d'un DataCenter

Ainsi de même, et d'après les indications du standard, un Datacenter doit inclure plusieurs aires fonctionnelles:

- Une ou plusieurs entrées au centre.
- Aire de distribution principale (Une ou plusieurs).
- Aire de distribution horizontale.
- Aire des équipements de distribution.
- Câblage horizontal et backbone.



Norme ANSI/TIA-942 : TIER

La fiabilité d'un Data Center nous est indiqué par l'un des quatre niveaux appelés TIER, en fonction de leur redondance. Le plus haut numéro de TIER correspond à la plus grande disponibilité, ce qui indique des coûts de construction et maintenance plus importants.

TIER	% Disponibilité	% Arrêt	Durée des arrêts annuels
TIER I	99,67%	0,33 %	28,82 h.
TIER II	99,74 %	0,25 %	22,68 h.
TIER III	99,982 %	0,02 %	1,57 h.
TIER IV	100 %	0,01 %	52,56 minutes

Norme ANSI/TIA-942 : TIER I

TIER I – Niveau 1 (Basique) :

- Disponibilité 99,671 %
- Sensible aux interruptions, qu'elles soient planifiées ou pas.
- Une seule entrée de courant électrique et de distribution de la climatisation, sans composants redondants.
- Sans exigences de sol surélevé
- Générateur indépendant
- Délai de mise en service: 3 mois
- Temps d'inactivité annuel: 28,82 heures
- Doit être fermé complètement pour la maintenance préventive

Norme ANSI/TIA-942 : TIER II

TIER II- Niveau II (Composants redondants)

- Disponibilité 99,741 %.
- Moindre sensibilité aux interruptions.
- Une seule entrée de courant électrique et de distribution de la climatisation, avec un composant redondant.
- Inclus sol surélevé, UPS et générateur.
- Délai de mise en service: 3 à 6 mois.
- Temps d'inactivité annuel: 22,0 heures.
- La maintenance de l'alimentation et autres parts de l'infrastructure obligent à une fermeture de traitement.

Norme ANSI/TIA-942 : TIER III

TIER III- Niveau III (Maintenance concourante)

- Disponibilité 99,982 %.
- Data center: Le standard TIA 942 Pas d'interruption de fonctionnement pour les pauses planifiées, mais possibilité de problèmes pour les cas imprévus.
- Accès de courant et climatisation multiples, par un seul cheminement actif. Inclus composants redondants (N+1).
- Délai de mise en service: 15 à 20 mois.
- Temps d'inactivité annuel: 1,6 heures.

Norme ANSI/TIA-942 : TIER IV

TIER IV- Niveau IV (Tolérant aux erreurs)

- Disponibilité 99,995 %.
- Pauses planifiées : sans interruption de fonctionnement pour les data critiques. Possibilité de soutenir un défaut imprévu sans dommages critiques.
- Accès de courant et climatisation multiples. Inclus composants redondants $2(N+1)$. 2 UPS avec redondance $(N+1)$ chacun.
- Délai de mise en service: 15 à 20 mois.
- Temps d'inactivité annuel: 0,4 heures.

Disponibilité des serveurs

Un objectif, assurer « la Haute disponibilité » des serveurs et des services.

- On définit la haute disponibilité comme un système permettant d'assurer une continuité opérationnelle d'un service sur une période donnée. Pour mesurer la disponibilité, on utilise une échelle qui est composée de 9 échelons. Un service Hautement Disponible est 99% disponible soit moins de 3,65 jours par an.
- Les 9 échelons sont :
 - **Redondance des matériels**
 - **Maintien des applications et mises à jour des logiciels**
 - **Reprise sur incident au cœur du dispositif**
 - **Disponibilité d'internet**
 - **Disponibilité réseau**
 - **Plans de secours**
 - **SLA pour les prestataires (GTR)**
 - **Disponibilité du débit**

Disponibilité des serveurs : stockage local

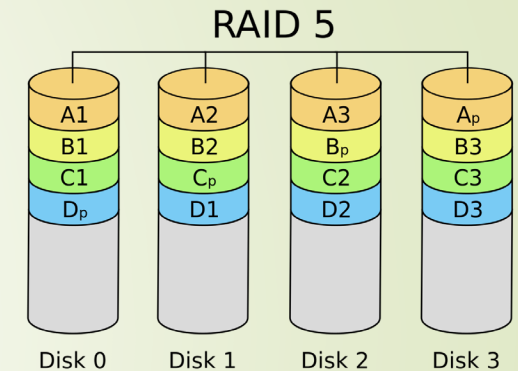
Un objectif, assurer « la Haute disponibilité » et la tolérance de panne sur les stockages locaux.

Solution :

- RAID
- Volumes logiques

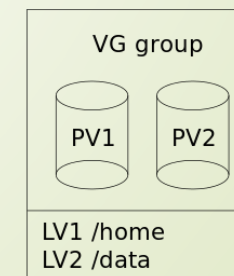
RAID :

Le RAID est un ensemble de techniques de virtualisation du stockage permettant de répartir des données sur plusieurs disques durs afin d'améliorer soit les performances, soit la sécurité ou la tolérance aux pannes de l'ensemble du ou des systèmes.



Volumes logiques :

La gestion par volumes logiques (en anglais, logical volume management ou LVM) est à la fois une méthode et un logiciel de gestion de l'utilisation des espaces de stockage d'un ordinateur. Il permet de gérer, sécuriser et optimiser de manière souple les espaces de stockage en ligne dans les systèmes d'exploitation de type UNIX.



Disponibilité des serveurs : Virtualisation du stockage

Pour faire face à la complexité des architectures distribuées de l'informatique en réseau, le stockage et la sauvegarde des données s'apprêtent à emprunter cette " voie naturelle de communication ". Résultats : plus de souplesse, moins de dépenses liées à l'administration des données, mais plus de difficultés liées à des technologies encore peu matures.

Les solutions principalement cités pour la virtualisation du stockage :

- Les réseaux SAN (Storage Area Networks) / DAS (Direct Acces Storage) / NAS (Network Attached Storage)

La technologie SAN amène également une evolution au niveau des moyens réseaux :

- Les profocoles comme iSCSI
- Le Fiber Channel.
- Duplication en mode "block"

Et enfin, la virtualization et tous ces moyens amènent une autre manière de stocker (un stockage n'est plus forcément effectué sur un support physique, mais dans des fichiers, ce qui induit :

- thin provisioning
- over-subscription
- thin persistence.

Disponibilité des serveurs : Le réseau

Toutes ces évolutions doivent reposer sur une couche de communication fiable, ainsi, on peut citer un certain nombre de protocoles réseau qui visent à assurer la haute disponibilité et l'optimisation des liens, comme par exemple :

- **L'agrégation de liens – LACP** (Link Aggregation Control Protocol) - IEEE 802.3ad

- **VPC** (Virtual PortChannel)

Le VPC signifie virtuel Port channel ou Port Channel avancé. Il est également connu sous le nom de **multi-châssis Port Channel**. Le Port Channel traditionnel ne peut pas regrouper les liens connectés à deux périphériques différents. Par exemple Si le commutateur **A** est connecté au commutateur **B** et au commutateur **C**, alors le Port Channel ne peut pas être formé en regroupant les liens des commutateurs **B** et **C**.

- **MSTP (Multiple Spanning Tree Protocol) - IEEE 802.1q :**

Le Spanning Tree Protocol (aussi appelé STP) est un protocole réseau de niveau 2 permettant de déterminer une topologie réseau sans boucle (appelée algorithme de l'arbre recouvrant) dans les LAN avec ponts.

Le Multiple Spanning Tree Protocol (MSTP) est une extension de RSTP (Rapid Spanning Tree Protocol) dans laquelle une instance de RSTP existe par groupe de VLAN.

Disposer de plusieurs instances de STP permet de mieux utiliser les liaisons dans le réseau, si la topologie STP est différente pour certains groupes de VLAN.

Les RTO et RPO

Le RTO c'est quoi ?

- Le RTO ou Recovery Time Objective, peut se traduire par la durée maximale d'interruption admissible. Il s'agit du temps maximal acceptable pendant lequel une ressource informatique (serveur, réseau, ordinateur, application) peut ne pas être fonctionnelle suite à une interruption majeure de service.
- Cette durée est définie à l'avance, et ce en fonction des besoins de production d'une entreprise vis-à-vis de la ressource informatique.
- Elle peut être aussi appelée « Temps de rétablissement »

Le RPO, c'est quoi ?

- RPO ou Recovery Point Objective, désigne la durée maximum d'enregistrement des données qu'il est acceptable de perdre lors d'une panne. Le fait de quantifier le RPO définit en fait les objectifs de sauvegarde, ce qui demande de connaître la volumétrie et les fenêtres de sauvegarde.
 - Par exemple, si le RPO est défini à 24 heures et que la volumétrie est faible, alors on peut considérer que une sauvegarde complète en fin de journée suffit.
 - En revanche, si le RPO est très faible comme c'est le cas dans les secteurs de la banque ou des télécommunications, alors plusieurs sauvegardes seront nécessaires par jour, et en fonction de la volumétrie, différentes techniques de sauvegarde seront utilisées.

La RPO

LA STRATEGIE ET L'IMPACT SUR LES ENTREPRISES :

- La **perte de données maximale** admissible (PDMA), en anglais **recovery point objective (RPO)** quantifie **les données qu'un système d'information peut être amené à perdre par suite d'un incident**.
- Usuellement, elle exprime une durée entre l'incident provoquant la perte de données et la date la plus récente des données qui seront utilisées en remplacement des données perdues.
- Cette durée est exprimée généralement en heures ou minutes.
- La RPO est souvent déterminée par la fréquence et la nature des sauvegardes effectuées sur les ressources informatiques. Toutefois, les données utilisées en remplacement des données perdues ne proviennent pas nécessairement d'une sauvegarde/restauration. Elles peuvent par exemple être reconstruites à partir de journaux de transactions, être issues d'une réplication, d'une copie ou d'un rejeu différé...



QU'EST QU'UN PRA ?

- Un Plan de Reprise d'Activité (PRA) est une procédure qui permet d'assurer la reprise des activités, en mode dégradé ou à plein régime, de votre entreprise en cas de sinistre (inondation, coupure électrique, incendie, destruction de données vitales...)
- L'objectif principal est d'anticiper et d'atténuer les effets dévastateurs d'une crise ou catastrophe naturelle sur la pérennité de vos activités. C'est un document qui répertorie les démarches à entreprendre pour reconstruire son système informatique en cas de crise importante et la remise en route des applications nécessaires aux activités d'une entreprise.

Les PCA et PRA

QU'EST QU'UN PCA ?

- Un Plan de Continuité d'Activité (PCA) est une procédure qui permet d'assurer la continuité des activités d'une entreprise, sans perte de données et qui offrira un accès au SI sans rupture d'exploitation.
- Si la sécurité est souvent abordée avec une approche orientée logiciel (anti-spam, anti-virus...), elle doit être encadrée par des dispositifs plus structurants que sont le PRA et le PCA.

Les PCA et PRA

COMMENT METTRE EN PLACE UN PCA ? (généralités)

- Un PCA vous permet d'anticiper et de minimiser les impacts légaux, financiers et en termes d'image d'un sinistre affectant votre entreprise.
- Trois étapes sont nécessaires pour mettre en œuvre un plan de continuité d'activité :
 - identifier les besoins de continuité ;
 - établir la base documentaire définissant toutes les procédures de continuité ;
 - tester régulièrement votre PCA pour corriger ses manques et incohérences.

COMMENT METTRE EN PLACE UN PRA ? (généralités)

- Une simple sauvegarde ne fait pas un bon PRA ! On peut y prévoir :
 - la présence de sites secours ;
 - la redondance de données entre **data centers** ;
 - les paramètres de redémarrage des applications ou des machines.

LA STRATEGIE ET L'IMPACT SUR LES ENTREPRISES :

► Les enjeux de cybersécurité

- A l'ère du cloud computing et de sa virtualisation, on connaît les proportions que peut prendre une cyberattaque.
- 93 % des entreprises ont été victimes de tentatives de fraude en 2016.
- Ce chiffre montre l'intensité de la menace. Le hacking est protéiforme : virus, logiciels espions, cheval de Troie... Quel que soit le système d'exploitation utilisé, personne n'est à l'abri.

► Des impacts plus profonds

- Un dommage collatéral moins quantifiable, et cependant tout autant dommageable, est la cessation de service pour votre d'activité. Lors d'un plantage de l'infrastructure informatique, les collaborateurs n'ont plus accès à leurs outils de travail. Pour autant, le compteur tourne : une perte sèche pour l'entreprise.

Exemple en milieu hospitalier

- La cyber-résilience est la capacité pour un établissement de santé à anticiper, prévenir, répondre et récupérer d'une cyberattaque. Elle implique la mise en place de mesures de sécurité informatique et de gestion des risques, ainsi que la formation du personnel à la sécurité informatique. La cyber-résilience vise à minimiser les perturbations du système de santé, à préserver la confidentialité et l'intégrité des données des patients, et à garantir la disponibilité des services de soins de santé essentiels en cas de cyberattaque.

La cyber-résilience est essentielle pour garantir la continuité des soins.

Exemple : le PRA en milieu hospitalier

- J'ai un PRA-I donc j'ai couvert le risque ?
 - Le PRA-I des ES a été pensé pour faire face à une panne classique. La cyber-attaque occasionne des dysfonctionnements (voir panne) du SI mais n'est pas une panne classique et ne doit pas être traitée comme telle.
- Combien de temps pour remettre en fonction un SI ?
 - L'expérience des autres établissements montre la difficulté de remédiation du SI suite à une cyber-attaque. La moyenne annoncée est de plusieurs mois dont au moins 15 jours en crise majeure !
- Pourquoi ce n'est pas qu'un problème technique ?
 - La DSI gère la remédiation mais pendant ce temps, il faut continuer à soigner les patients. Il faut donc penser l'organisation de crise qui peut durer des semaines voir plusieurs mois.
80% d'organisation – 20% de technique

Le plan de cyber résilience

- Définition d'un plan de résilience (incluant le métier !)
- Gouvernance
 - Cellule de crise
 - Cellule de communication
 - Cellule d'intervention DSI/Directions métiers
 - Remédiation
 - Accompagnement dans les services
 - TaskForce (PRIS) externe dédiée à l'arrêt de l'attaque
- Définition du périmètre métier à défendre
- Adapter la sûreté de l'ES durant la crise
- Cartographier les SI nécessaires et les organisations métiers
- Définir une organisation (fonctionnelle et technique) pour couvrir la période de crise sans ou presque sans informatique
- Abonder le PRA-I des process de remédiation
- Jouer le plan de résilience de manière régulière par des simulations

Les étapes en amont

- **Identifier:** la maturité de l'ES face aux cyber-attaques. En fonction des objectifs (périmètre à définir), de ses contraintes, il convient de réaliser un état des lieux factuel de ce qui est mis en place pour répondre aux cyber-attaques (vs ce qu'il faudrait mettre en place) et de définir une stratégie et un plan d'action. Les procédures dégradées doivent être écrites avec les métiers.
- **Protéger :** la deuxième étape vise à sensibiliser et former les équipes, renforcer les contrôles d'accès, identifier les failles et les corriger, mettre en place une correction systématique des vulnérabilités. Dans ce contexte, le « zero trust » doit être un principe directeur. Les procédures métiers doivent être accessibles même en cas d'arrêt complet du SIH. Des exercices de crise doivent être joués régulièrement. **La sauvegarde des données doit être sanctuarisée !**
- **Détecter :** un dispositif de détection doit être mis en œuvre pour identifier les nouvelles menaces internes et externes. La décision de déclencher le plan cyber-résilience doit être prise en dehors de toute émotion et en toutes circonstances.

Les étapes en aval

- **Réagir** : il s'agit du cœur de la stratégie de cyber-résilience. Un plan d'intervention et d'orchestration doit faire gagner un temps précieux sur le déroulement des actions à entreprendre. Il convient d'engager des prestataires de réponse aux incidents de sécurité (PRIS) pour repousser les attaques et remédier aux dégâts en rétablissant les systèmes et en corrigeant les vulnérabilités. L'ES devra également décider de sa stratégie de communication envers les collaborateurs, les partenaires et les patients.
- **Restaurer** : il faut enfin rétablir l'accès aux données, reconstruire les applications critiques, prioriser la mise en œuvre des ressources pour accélérer la récupération
- Le concept de 3-2-1 (3 copies, 2 supports différents, 1 copie externalisée) doit être parfaitement mis en œuvre (immutabilité des données, identification de la dernière copie saine, ...).

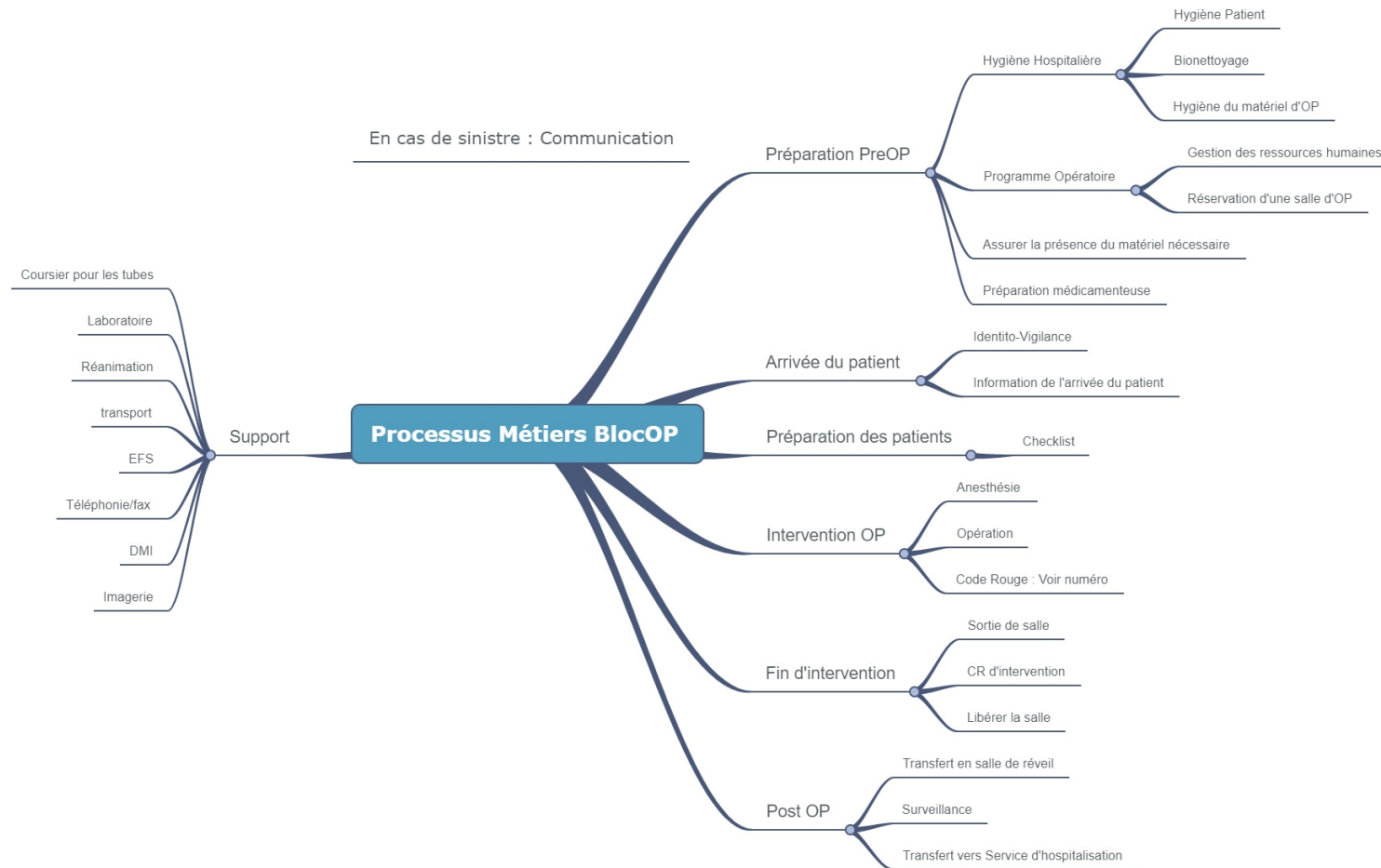
Le cloud est-il la solution ?

- Le challenge soulevé par un projet de résilience trouve sa solution dans l'organisation associée à une solution technique.
- L'externalisation **complète** dans le Cloud est une utopie pour les grosses structures:
 - l'informatique biomédical est difficilement externalisable
 - Le dossier patient peut être entièrement externalisé mais les coûts risquent d'être très élevés selon la complexité du SI et les interactions avec les logiciels sur site ne permettront au mieux un mode très dégradé
 - Le nombre de logiciels est immense et nombreux d'entre eux ne sont pas externalisables facilement (OS AIX, interfaces propriétaires....)
 - La première mesure préconisée est de couper les accès Internet
- **Le cloud hybride peut être une solution techniquement intéressante dans la mise en œuvre de son PRA-I mais attention à bien garder la maîtrise du SI. A défaut, la gouvernance des données sera perdue !**

L'externalisation est-elle une solution ?

- Néanmoins le Cloud peut apporter plusieurs solutions:
 - Maintenir des moyens de communication opérationnels
 - Offrir une sécurisation des sauvegardes chiffrées
 - Permettre de restaurer les sauvegardes dans une infrastructure tierce les éléments les plus importants pour relancer au plus vite l'activité in situ
 - Améliorer à faible coût sa SSI (exemple: SOC managé)
 - Offrir un accès à des données sanctuarisées en mode SaaS
- Les contraintes réglementaires doivent être évaluées avant tout projet dans le cloud (rgpd, cloud souverain, hds...)
- Le Cloud souverain permet de se conformer à la loi en vigueur dans un État ou une zone de juridiction particulière. Il est ici question du RGPD (Règlement Général sur la Protection des Données), introduit par l'UE en 2018. De plus, la certification HDS (hébergeur de données de santé) est souvent une obligation dans le secteur de la santé.

Cartographier les processus métiers



Les procédures dégradées

- On doit cartographier les adhérences au système d'information de chaque processus métier.

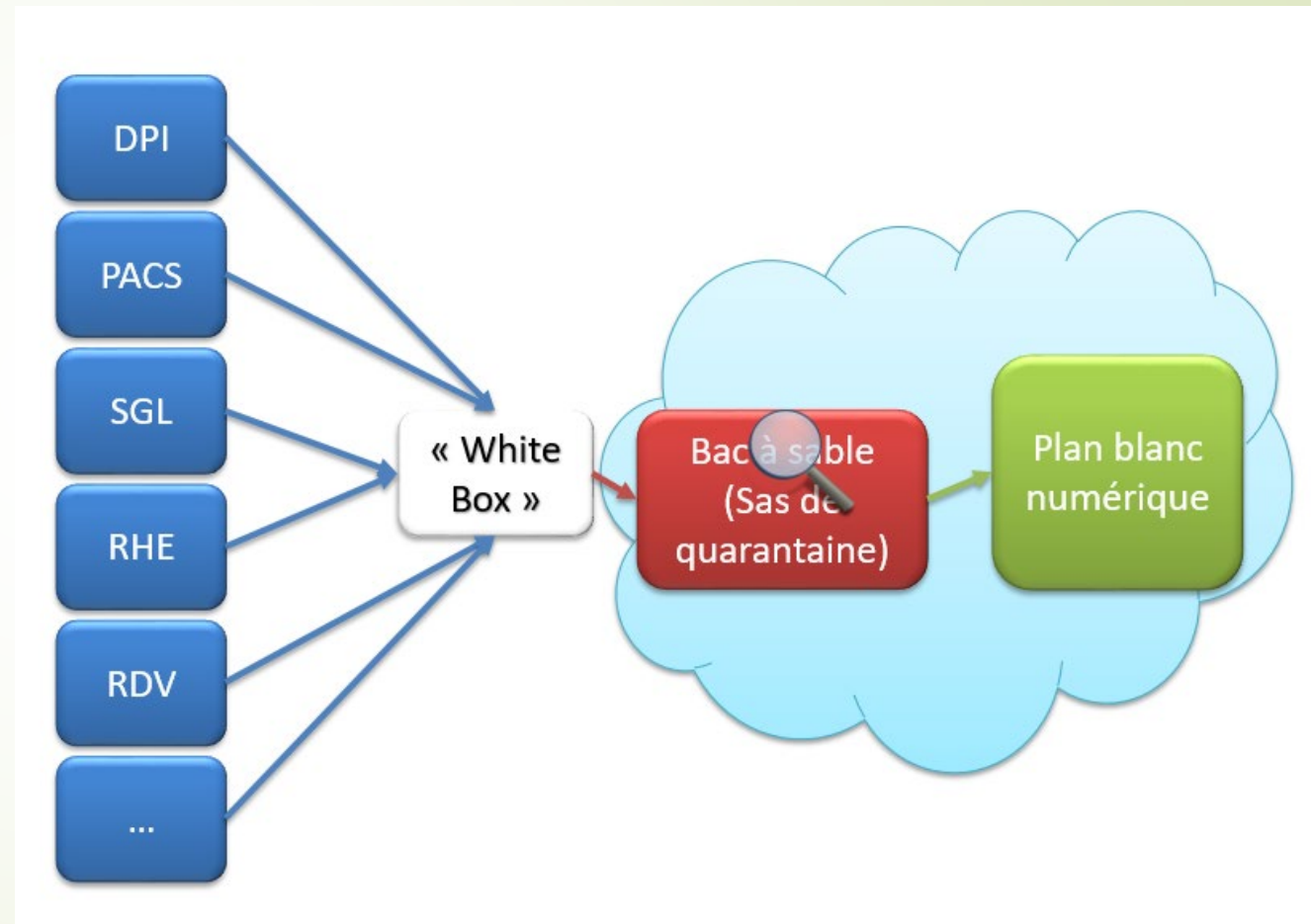
Etape	Nom du Process	Outil utilisé	Commentaire	Lien avec un service externe	délai avant procédure dégradée	Solutions palliatives
Préparation Pré Op	Hygiène Patient					Papier
Préparation Pré Op	Hygiène matériel d'OP			Stérilisation		Papier
Préparation Pré Op	Bionettoyage					Papier
Préparation Pré Op	Programme Opératoire					Papier
Préparation Pré Op	Gestion des ressources humaines			Urgence		Téléphone
Préparation Pré Op	Réservation d'une salle OP					Téléphone
Préparation Pré Op	Assurer la présence du matériel					Téléphone
Préparation Pré Op	Oxygène					Téléphone
Préparation Pré Op	Commande de stupéfiants					Téléphone Papier
Arrivée du patient	Identito-Vigilance					Papier
Arrivée du patient	Edition Etiquette					Etiquette pré imprimée
Arrivée du patient	Admission urgente			Urgence		Téléphone

Le SI de secours pour les soignants

L'idée est de stocker toutes les données nécessaires à la prise en charge du patient dans un espace de stockage objet. L'idéal est de s'appuyer sur des solutions qui offrent des outils de visualisation autonome de ces données.

Ce type d'infra peut-être externalisée ou on Premise (dans ce cas sur un réseau dédié et totalement séparé de la prod !)

L'avantage est de disposer d'un SI **minimal** hors d'attente des attaques avec des données non modifiables



La cellule d'intervention

Il faut constituer trois missions avec du personnel dédié à chacune d'elles:

- **L'élimination de la menace** : Appel à des sociétés spécialisées (PRIS)
- **La gestion de la crise**
 - Mettre en place les outils en mode autonome nécessaires à la continuité des soins
 - Accompagner sur place le personnel à la gestion des outils en mode dégradé
 - Anticiper les besoins en ressources humaines
- **La résolution de la crise**
 - Déclenchement du PRA-I ou tout autre mode nécessaire au rétablissement du SI
 - Equipe de test des outils rétablis avant remise en production

Un correspondant informatique et biomédical doivent être nommés afin de remonter le plus précisément possible les impacts sur le SIH et l'état de remédiation.

Les applications

Quelques services à ne pas négliger en cas de défaillances informatiques:

- **La prise d'identité:** Pensez à mettre à disposition des fiches pré-imprimées pour saisir l'identité des patients dans chaque bureau d'accueil
- **Les moyens de communication :** la communication est le pilier d'une bonne organisation. Si la vôtre est HS, utilisez en une autre !
 - Pensez à mettre en place un système de communication en dehors de votre VOIP, voir de votre PABX (au minimum un fax et un téléphone portable par service.
 - L'utilisation d'une messagerie sécurisée de crise style TCHAP peut être intéressant).
 - Un serveur de mail externalisé doit être préparé en amont pour fonctionner en cas de sinistre
- **La gestion des transports:** Pensez à mettre en œuvre une cellule de gestion de crise pour le transport (logistique et patient)

Les applications

Quelques services à ne pas négliger en cas de défaillances informatiques:

- **La pharmacie, la stérilisation, le biomédical, mais aussi le service des achats** sont des services supports essentiels pour la continuité des soins. Un système en mode dégradé doit être défini en amont avec du matériel autonome du SIH.
- **Toute la partie industrielle d'un hôpital** : Gestion des alarmes, des automates, des accès physiques sécurisés....

Les applications

Afin de ne rien oublier, l'élaboration d'une liste des applications essentielles avec leur niveau de criticité doit être disponible dans le PR.

La DSI ne doit pas prendre la responsabilité de l'ordonnancement lors de la relance d'un SI. Cela doit être clairement défini avec le groupe de travail du Plan de résilience en amont.

Les applications

Un inventaire des actifs doit être disponible

La DSI et la cellule de crise doivent être dans la capacité d'adapter les affectations du matériel en temps réel

- Préparation des postes en mode industriel avec différentes images adaptées aux besoins des services
- Les imprimantes et autres moyens de communication doivent être capables de fonctionner en mode dégradé (perte du réseau).
- Un accès Internet de secours doit être prêt et accessible afin de permettre la fluidité de la communication interne nécessaire à la gestion de la crise mais aussi à la production du soin (transport par exemple).
- Des conventions doivent être signées en amont avec des établissements partenaires pour absorber l'activité en cas de besoin

Les procédures

Les procédures doivent être accessibles même en cas d'arrêt total du SIH:

- Les procédures sur l'organisation des soins, les transports,
- Un inventaire des actifs
- La liste des contrats et numéros de téléphones des fournisseurs et prestataires informatiques, logistiques, transports...
- Les procédures informatiques (base de connaissances)
- Les mots de passe (keypass ou papiers dans le coffre par exemple)

Le plan de résilience complet doit être disponible hors ligne (sur un poste en mode autonome ou au format papier)

En 3 points:

- **Disposer de solutions en mode dégradé métiers pour les activités prioritaires**
- **Tester régulièrement et mettre à jour les solutions techniques**
- **Programmer régulièrement des exercices de simulation de crise**